

10. 컴플라이언스 체크리스트 (Compliance Checklist)

10. 컴플라이언스 체크리스트 (Compliance Checklist)

문서 정보

버전: v1.0 | 작성일: 2026-05-03 | 상태: 초안 | 작성자: 경북대학교 AI/빅데이터 전문가 양성 과정 — TBD팀

⚠ 법적 주의: 본 문서는 학생 팀의 자체 정리이며, **법무 자문을 대체하지 않습니다**. 정식 출시 전 법률 전문가의
료자문위 검토 필수.

한 줄 요약

의료 도메인 프로젝트가 반드시 준수해야 할 5개 법규(의료법·약사법·건기식법·개인정보보호법·정보통신망법) + 인증(ISMS-P) + 앱스토어 심사 + 표현 가이드 + 비상대응 까지 통합. “학생 프로젝트지만 법규·거버넌스까지 갖춘 팀”이라는 인상을 남기는 핵심 문서.

목차

- 1. 적용 법령·표준 지도
- 2. 의료법 (Medical Service Act)
- 3. 약사법 (Pharmaceutical Affairs Act)
- 4. 건강기능식품법
- 5. 개인정보보호법
- 6. ISMS-P 인증
- 7. DTx 해당 여부 판단
- 8. 앱스토어 심사
- 9. 카피라이트·인용 표기
- 10. 표현 가이드 — 진단 X / 권장 O
- 11. 비상 시 대응
- 12. Phase별 컴플라이언스 체크리스트

1. 적용 법령·표준 지도



2. 의료법 (Medical Service Act)

2.1 핵심 금지 사항

본 프로젝트가 절대 해서는 안 되는 행위:

#	금지 행위	근거
✖	“〇〇질환입니다” 같은 진단 제공	의료법 §27 (무면허 의료행위)
✖	“〇〇약을 드세요” 같은 처방 제공	의료법 §27
✖	“〇〇병원에 가세요” 외 특정 의료기관 알선	의료법 §27의2
✖	의사·약사로 오인되는 표현	의료법 §17, §27
✖	치료 효과를 단정적으로 보장	의료법 §56 (의료광고 금지)

2.2 허용되는 표현 (비의료 건강관리서비스)

✓	허용 행위
✓	KDRIs 기준 권장 섭취량 안내
✓	일반 식이·운동 권고 (질병 진단 없이)
✓	영양소 결핍 가능성 안내 (질병명 X)
✓	“전문의·약사와 상담을 권장합니다” 안내
✓	일반인 대상 영양·운동·체중 정보 제공

2.3 면책 고지 표준 문구

메인 디스클레이머 (모든 권고 화면)

본 서비스에서 제공하는 정보는 일반적인 건강 관리를 위한 참고 자료이며, 의사·약사·영양사의 전문적 진단이나 처방을 대체하지 않습니다.

증상이 있거나 만성질환을 앓고 계신 경우, 반드시 전문가와 상담하시기 바랍니다.

부속 디스클레이머 (영양제 화면)

영양제는 의약품이 아니며, 질병의 예방이나 치료를 보장하지 않습니다. 약을 복용 중이신 경우, 영양제와의 상호작용에 대해 의료진과 상담하세요.

 부속 디스클레이머 (체중 예측 화면)

체중 변화 예측은 평균적인 수치를 바탕으로 산출되며, 개인의 대사·체질·생활습관에 따라 결과가 달라질 수 있습니다. 급격한 체중 변화는 건강에 해로울 수 있으니 의료진과 상담하세요.

2.4 본 프로젝트 적용 체크리스트

- ☐ 모든 권고 화면 상·하단에 메인 디스클레이머 표시
- ☐ 영양제·체중 화면에 부속 디스클레이머 추가
- ☐ “진단”, “처방”, “치료” 단어 UI에서 사용 금지 (코드 검수)
- ☐ AI 응답에 진단 표현 검출 시 자동 차단 (LLM 시스템 프롬프트)
- ☐ 의료자문위 검토 시 표현 일관성 확인
- ☐ 법무 검수 시 진단 표현 0건 통과

3. 약사법 (Pharmaceutical Affairs Act)

3.1 핵심 금지 사항

#	금지 행위	근거
✗	특정 의약품 추천·이름 명시	약사법 §61, §68
✗	처방약 직접 알선 (대리 구매·배송)	약사법 §47
✗	의약품을 건강기능식품처럼 광고	약사법 §63
✗	의약품의 효능·효과를 사용자에게 직접 설명	약사법 §68

3.2 허용되는 표현

✓	허용 행위
✓	건강기능식품 성분 안내 (식약처 기능성 인정 원료)
✓	영양제 라벨에 명시된 정보의 단순 표시
✓	“약을 복용 중이라면 약사와 상의하세요” 안내
✓	일반의약품과 영양제의 차이점 일반 정보

3.3 본 프로젝트 적용

- 영양제 라벨 인식 결과는 **사용자가 가진 제품의 정보 표시일 뿐 추천 X**
- 결핍 영양소 권고 시 **성분명만 안내** (예: “비타민C 추가 섭취 권장”) → 특정 제품·브랜드 X
- 처방약과의 상호작용 정보는 **공식 출처(식약처 의약품안전나라)에서만 인용**

3.4 체크리스트

- ☐ 특정 영양제·의약품 브랜드 추천 기능 없음 (검색·선택만)
- ☐ AI 응답에서 “OO 의약품”을 추천하는 텍스트 자동 차단
- ☐ 약사법 위반 가능 표현 검수 (Phase 3 법무 검수 시)
- ☐ 영양제 성분 정보는 식약처 건강기능식품 원료 DB만 사용

4. 건강기능식품법

4.1 핵심 사항

본 프로젝트는 영양제(=건강기능식품)를 다루므로 **건강기능식품에 관한 법률** 적용.

#	준수 사항	근거
✓	식약처 기능성 인정 원료 만 추천 (예: 루테인, 밀크씨슬, 코엔 자임Q10)	건기식법 §16
✗	식약처 미인정 원료의 기능성 표시 금지	건기식법 §18
✗	“병이 낫는다”, “즉효” 같은 과대광고 금지	건기식법 §18

4.2 본 프로젝트 적용

- 알고리즘 @ (목적별 분석)에서 추천하는 모든 원료는 식약처 기능성 인정 목록 매트릭스에서만 선택
- 식약처 고시 기능성 표현 그대로 사용 (예: “간 건강에 도움을 줄 수 있음”)

4.3 체크리스트

☐

추천 원료 목록 = 식약처 건강기능식품 원료 DB와 일치

☐

기능성 표현 = 식약처 고시 그대로 인용 (창작 금지)

☐

원료별 일일 섭취량 = 식약처 기준 준수

☐

흡연자 등 분기 처리 (예: 루테인 + 흡연자 경고)

5. 개인정보보호법

5.1 민감정보 분류

본 프로젝트가 수집하는 데이터의 법적 분류.

데이터	분류	별도 동의 필요
이름, 이메일	일반 개인정보	일반 동의
나이, 성별, 키, 몸무게	일반 개인정보	일반 동의
만성질환 정보	민감정보 (건강 정보)	★ 별도 동의 필수
복약 정보	민감정보	★ 별도 동의 필수
검진 기록 (LDB 연계 시)	민감정보	★ 별도 동의 필수
걸음수, 심박수	민감정보 (생체정보)	★ 별도 동의 필수
영양제·식단 사진	일반 개인정보 (이미지)	일반 동의

⚠ **중요:** 민감정보는 일반 동의에 포함 불가. 별도 항목·별도 화면으로 동의받아야 함.

5.2 별도 동의 UI 설계

동의 화면 구조 (예시)

☒ [필수] 서비스 이용약관	
☒ [필수] 개인정보 수집·이용 동의	
☐ [선택] 마케팅 정보 수신	
민감정보 별도 동의 (각각 동의)	
☐ [필수] 건강 정보 (만성질환·복약) 수집·이용	
부족 영양소 분석에 사용됨	
☐ [필수] 생체 정보 (걸음수·심박수) 수집·이용	
활동점수·체중 예측에 사용됨	
☐ [선택] 의료기관 진료 기록 연동 (LDB)	
향후 약·영양제 상호작용 검토	
[취소]	[동의하고 시작하기]

5.3 가명정보 처리

만성질환 데이터를 통계·분석 목적으로 활용 시:

- 직접 식별자 제거: 이름, 전화번호, 이메일, IP 주소
- 간접 식별자 일반화: 생년월일 → 연령대 (10세 단위), 주소 → 시/도
- 결합 위험 평가: 사용자 ID 해시, 외부 데이터와의 결합 가능성 검토

5.4 데이터 주체의 권리 (필수 구현 기능)

권리	구현
열람권	마이페이지 > 내 데이터 보기
정정·삭제권	마이페이지 > 데이터 수정/삭제
처리정지권	마이페이지 > 분석 일시 정지
동의 철회권	설정 > 동의 항목별 철회
회원탈퇴 시 데이터 즉시 삭제	백업도 90일 내 폐기

5.5 체크리스트

☐

별도 동의 UI 구현 (3가지 민감정보 항목별)

☐

회원가입 후 진입 시점에 동의 받기 (데이터 수집 전)

- ☐ 마이페이지에 데이터 열람·수정·삭제 기능
- ☐ 회원탈퇴 시 즉시 삭제 + 백업 폐기 절차
- ☐ 가명정보 처리 후에만 통계·분석 사용
- ☐ 개인정보처리방침 페이지 게시
- ☐ 개인정보 보호책임자 지정·표시

6. ISMS-P 인증

6.1 인증 개요

항목	내용
공식 명칭	정보보호 및 개인정보보호 관리체계 인증
운영 기관	한국인터넷진흥원 (KISA)
인증 기준	101개 (관리체계 16 + 보호대책 64 + 개인정보 단계별 21)
유효기간	3년, 매년 사후심사
소요 기간	갭 분석 → 컨설팅 → 심사 → 인증 (총 6~12개월)

6.2 본 프로젝트의 ISMS-P 위치

항목	학생 단계	정식 출시 시
의무 인증 대상	❌ 아님	△ (매출·이용자 기준 도달 시)
권고 사항	✅ 자발적	✅ 강력 권고 (의료 데이터 신뢰도)
본 프로젝트 범위	갭 분석 + 일부 통제 적용	본격 인증 추진

6.3 본 프로젝트가 적용할 핵심 통제

ISMS-P 101개 기준 중, 본 프로젝트가 우선 적용할 항목:

관리체계 (16개 중 일부)

- ☐ 정보보호 및 개인정보보호 정책 수립 (docs/security_policy.md)
- ☐

정보보호 책임자 지정 (PM 역할)

☐

정기 위험 평가 (분기별 회고 시 점검)

보호대책 (64개 중 일부)

☐

AES-256 컬럼 암호화 (PostgreSQL pgcrypto)

☐

TLS 1.3 적용 (모든 API 통신)

☐

API 키 관리 (.env, GitHub Secrets, 절대 commit X)

☐

접근 권한 통제 (FastAPI 권한 미들웨어)

☐

감사 로그 (PHI 접근 시 누가·언제·무엇을)

☐

백업·복구 (PostgreSQL 일일 백업)

개인정보 단계별 (21개 중 일부)

☐

수집 동의 (별도 동의 UI)

☐

이용·제공 통제 (목적 외 이용 금지)

☐

파기 절차 (회원탈퇴 시 즉시)

6.4 체크리스트

☐

정보보호 정책 문서 작성

☐

민감정보 컬럼 AES-256 암호화 구현

☐

모든 API에 TLS 1.3 강제

☐

PHI(개인 건강 정보) 접근 감사 로그

☐

정기 백업·복구 테스트

☐

(정식 출시 전) ISMS-P 컨설팅 갭 분석

7. DTx 해당 여부 판단

7.1 DTx (디지털치료기기) 정의

식약처 기준:

다음은 모두 만족 시 → 디지털치료기기 (의료기기로 분류, 식약처 허가 필요)

- └ ① 치료 작용기전의 과학적·임상적 근거가 있고
- └ ② 질병 예방·관리·치료를 목적으로 하며
- └ ③ 특정 질환자에게 증상 개선 프로토콜 제공

7.2 본 프로젝트의 DTx 해당성 판단

기준	본 프로젝트	결과
① 치료 작용기전 임상 근거	❌ (참고 정보만 제공)	DTx 아님
② 질병 예방·관리·치료 목적	❌ (일반 건강관리)	DTx 아님
③ 특정 질환자 증상 개선 프로토콜	❌ (일반 권고만)	DTx 아님

→ 결론: 본 프로젝트는 비의료 건강관리서비스

7.3 비의료 건강관리서비스 포지셔닝

- └ ☒ 영양·운동·체중 일반 권고만 제공
 - └ ☒ 질병 치료 목적이 아니고
 - └ ☒ 일반인 대상 웰니스 서비스
- 비의료 건강관리서비스 → 식약처 허가 불필요

7.4 DTx 경계를 넘지 않기 위한 가드

향후 기능 추가 시 DTx로 오인되지 않도록:

- ❌ “당뇨 치료 프로그램” 같은 이름 X
- ❌ “고혈압 환자를 위한 처방 가이드” X
- ❌ “이대로 따라하면 OO병이 납니다” X
- ☒ “당뇨 위험군을 위한 영양 관리 가이드” → 가능
- ☒ “고혈압 관리 시 주의 영양소” → 가능 (정보 제공)

7.5 체크리스트

☐

모든 기능이 “치료”가 아닌 “관리·참고”로 표현됨

☐

특정 질환자용 증상 개선 프로토콜 부재

☐

사전 법률 검토 (Phase 2~3)

☐

보건복지부 비의료 건강관리서비스 가이드라인 준수

☐

향후 DTx 진입 검토 시 별도 인허가 절차 (Year 3+)

8. 앱스토어 심사

8.1 Apple App Store

핵심 정책 (Health & Wellness)

정책	내용
5.1.1(ix)	건강 데이터 사용 목적 명확히 (Info.plist)
5.1.3	헬스 데이터 비공유 (제3자 앱 X)
1.4.1	위험한 의료 정보 금지
5.2.1	의약품·의료 광고 제한

심사 시 자주 발생하는 거절 사유

거절 사유	대응
Info.plist 사용 목적 모호	“건강 데이터를 분석하여 맞춤 권고를 제공합니다” 같은 명확한 한글 설명
면책 고지 누락	모든 권고 화면에 표시
HealthKit 데이터를 제3자에 전송	백엔드 전송 시 사용자 동의 + 익명화 명시
의료 진단 표현	진단 표현 검수

체크리스트

☐Info.plist `NSHealthShareUsageDescription` 작성 (한글)☐Info.plist `NSHealthUpdateUsageDescription` 작성☐

App Privacy 라벨 작성 (수집 데이터 명시)

☐

면책 고지 표시 스크린샷 준비

☐

Apple Developer Program 가입 (연 \$99, 학생 면제 가능 여부 확인)

☐

심사 거절 시 Apple Review Guidelines 재검토

8.2 Google Play Store

핵심 정책

정책	내용
Health Connect 정책	Health Connect 권한 사용 시 별도 동의 절차
민감 권한	ACTIVITY_RECOGNITION 등 사전 설명 필수
Personal & Sensitive Info	헬스 데이터 처리 방침 명확

체크리스트

☐

AndroidManifest.xml 모든 health 권한 선언

☐

권한 요청 전 사용 목적 다이얼로그 표시

☐

데이터 보안 섹션 (Data Safety) 작성

☐

개인정보 처리방침 URL 등록

☐

Google Play Developer 계정 (\$25 1회 결제)

☐

Health Connect 정책 동의

9. 카피라이트·인용 표기

9.1 데이터 출처 명시 (필수)

본 프로젝트가 사용하는 외부 데이터의 출처를 사용자에게 표시:

앱 내 "정보 출처" 페이지 (필수)

- 영양 기준: 한국인 영양소 섭취기준 (KDRIs 2020), 보건복지부
- 식품 영양 정보: 식품의약품안전처 식품영양성분 Open API
- 영양제 정보: 식품의약품안전처 건강기능식품 원료 DB
- 한식 정보: 농촌진흥청 국가표준식품성분표 (9개정판)
- 식품 이미지 학습 데이터: AI Hub 음식 이미지 데이터셋 (NIA)

9.2 라이선스 준수

자원	라이선스	의무
KDRIIs	공공저작물 자유이용	출처 표시
식약처 API	공공데이터	출처 표시
농진청 자료	공공저작물 자유이용	출처 표시
AI Hub 데이터셋	활용 동의 + 비상업	재배포 금지, 사용 목적 준수

9.3 체크리스트

☐

앱 내 "정보 출처" 페이지 구현

☐

모든 외부 데이터에 출처 표시

☐

AI Hub 데이터셋 사용 목적 준수 (학술·R&D)

☐

오픈소스 라이브러리 라이선스 표시 (`pubspec.yaml` , `requirements.txt` 기반)

10. 표현 가이드 — 진단 X / 권장 O

10.1 위반 표현 vs 대체 표현 (사례 모음)

영양 분석 화면

❌ 위반	✅ 대체	이유
“당신은 빈혈입니다”	“철분 섭취량이 권장량보다 낮습니다”	진단 → 정보
“이 질환에 걸리셨네요”	“이 영양소가 부족할 수 있습니다”	진단 → 가능성
“비타민 D가 결핍되었습니다”	“비타민 D 섭취가 권장량의 35% 수준입니다”	의학 용어 → 정량 정보
“당뇨 위험군입니다”	“혈당 관련 영양소 관리에 주의가 필요할 수 있습니다”	진단 → 일반 정보

영양제 추천 화면

❌ 위반	✅ 대체
“OO 비타민C를 드세요”	“비타민 C 섭취량을 늘리는 것이 권장됩니다”
“이 약을 추천합니다”	“비타민 D가 포함된 식품(달걀노른자, 등푸른생선)을 고려하세요”
“의약품 복용을 권장합니다”	“전문가와 상담을 통해 결정하세요”

체중 관리 화면

❌ 위반	✅ 대체
“이대로면 비만이 됩니다”	“현재 추세 시 1개월 후 체중이 약 1.2kg 증가할 수 있습니다”
“당장 다이어트하세요”	“건강한 체중 관리를 위해 식단·운동 균형이 중요합니다”
“이 식단이 답입니다”	“영양 균형을 고려한 식단 예시를 보여드립니다”

운동 권고 화면

❌ 위반	✅ 대체
“운동 부족으로 병이 옵니다”	“권장 걸음수의 60% 수준으로 활동하고 계십니다”
“이 운동이 처방입니다”	“활동량을 늘리는 한 가지 방법으로 다음을 권장합니다”

10.2 표현 검수 자동화

LLM 시스템 프롬프트 (Claude API 호출 시)

당신은 한국 의료법·약사법을 준수하는 건강 정보 어시스턴트입니다.

다음 단어는 절대 사용하지 마세요:

- "진단", "처방", "치료" (질병 관련)
- "보장", "확실히", "분명히" (효과 단정)
- 특정 약품·브랜드 이름
- "이 약", "이 의약품" (의약품 직접 추천)

대신 다음과 같이 표현하세요:

- "참고", "권장", "관리"
- "도움이 될 수 있습니다"
- "전문가와 상담을 권장합니다"

코드 레벨 표현 검출 (간단 정규식)

```
FORBIDDEN_TERMS = [
    "진단", "처방", "치료", "확실히", "분명히",
    "보장", "이 약", "이 의약품", "처방전",
]

def check_forbidden_terms(text: str) -> list[str]:
    """금지 표현 검출"""
    found = [term for term in FORBIDDEN_TERMS if term in text]
    return found

# 사용
issues = check_forbidden_terms(ai_response.content)
if issues:
    logger.warning(f"Forbidden terms detected: {issues}")
    # 응답 재생성 또는 차단
```

10.3 체크리스트

☐

LLM 시스템 프롬프트에 표현 가이드 포함

☐

금지 표현 자동 검출 함수 구현

☐

의료자문위 검토 시 UI 텍스트 전수 검사

☐

법무 검수 시 진단·처방 표현 0건 확인

☐

정기 검수 (분기별) — 신규 텍스트 추가 시

11. 비상 시 대응

의료 도메인 앱이 반드시 갖추어야 할 비상 대응 시나리오.

11.1 사용자 위급 신호 감지

시나리오 1: 자해·자살 의도 신호

사용자 입력에서 자해·자살 의도가 감지될 경우:

[감지 트리거]

- 식단 입력에 "안 먹는다", "굶는다" 반복
- AI 챗봇 대화에 자해·자살 관련 표현
- 극단적 체중 감량 목표 (체중의 10% 이상/월)
- 영양 섭취량이 안전 기준 미만 지속

[대응]

1. 즉시 다이어트·체중 권고 비표시
2. 정신건강 자원 안내
 - 자살예방상담전화 109
 - 정신건강위기상담전화 1577-0199
3. 의료자문위 알림 (사용자 동의 시)
4. 디스클레이머 강화 표시

시나리오 2: 식이장애 의심 신호

[감지 트리거]

- BMI 17 미만 + 추가 감량 목표
- 일일 섭취 1,000kcal 미만 지속
- "구토", "토함" 같은 키워드

[대응]

1. 칼로리 감량 권고 자동 비표시
2. 식이장애 전문 상담 안내
 - 한국섭식장애협회
3. 의료기관 상담 강력 권고

시나리오 3: 심각한 건강 이상 의심

[감지 트리거]

- 갑작스런 체중 급감 (3개월 5kg 이상)
- 심박수 비정상 (안정 시 100+ 또는 50- 지속)
- 사용자가 직접 입력한 증상 (가슴 통증 등)

[대응]

1. "전문 의료기관 상담을 강력히 권장합니다" 안내
2. 응급실 정보 (1339)
3. 일반 권고 일시 중단

위급 신호 대응 UI 예시

⚠️ 잠시만요	
입력하신 정보를 보니, 전문가의 상담이 필요할 수 있어 보입니다.	
💬 정신건강위기상담 ☎️ 1577-0199	
💬 자살예방상담 ☎️ 109	
🏥 응급의료정보 ☎️ 1339	
본 서비스는 의료적 진단을 제공하지 않습니다. 가까운 의료기관·전문가와 상담하시기 바랍니다.	
[상담 정보 자세히]	[닫기]

11.2 데이터 유출 사고 대응

Phase별 대응 절차

[Phase 1] 즉시 대응 (1시간 이내)

- └─ 유출 범위 파악
- └─ 추가 유출 차단 (서버 격리, API 키 폐기)
- └─ 내부 비상 연락망 가동

[Phase 2] 통보 (24시간 이내)

- └─ 개인정보보호위원회 신고 (개인정보보호법 §34)
- └─ 한국인터넷진흥원(KISA) 신고
- └─ 사용자 통보 (이메일·앱 푸시)

[Phase 3] 후속 (72시간 이내)

- └─ 원인 분석 보고서
- └─ 재발 방지 대책 수립
- └─ 외부 보안 감사 의뢰

[Phase 4] 사후 (1개월 이내)

- └─ 사용자 피해 구제 절차
- └─ ISMS-P 재심사 (해당 시)
- └─ 법적 책임 검토

11.3 의료자문위 알림 트리거

다음 상황 발생 시 즉시 의료자문위에 알림:

트리거	우선순위
알고리즘 출력에 진단·처방 표현 발견	🔴 즉시
사용자 신고 (잘못된 권고)	🔴 24시간 내
식약처·보건복지부 가이드라인 변경	🟡 1주일 내
KDRIs 갱신 발표	🟡 즉시 (수치 갱신)
새로운 만성질환 분류 추가	🟢 분기 내

11.4 체크리스트

- ☐ 위급 신호 감지 룰 정의 (LLM 프롬프트 + 룰 기반)
- ☐ 응급 자원 정보 페이지 구현 (1577-0199, 109, 1339)
- ☐ 데이터 유출 대응 절차서 작성
- ☐ 비상 연락망 (팀 + 회사 + KISA + 개인정보보호위원회)
- ☐ 의료자문위 알림 시스템 (이메일·메시지)
- ☐ 모의 훈련 (분기 1회, 정식 출시 후)

12. Phase별 컴플라이언스 체크리스트

각 Phase 종료 시 점검할 컴플라이언스 항목.

Phase 0 (기획·조사)

- ☐ 본 컴플라이언스 문서(10번) 팀 전체 공유·읽기
- ☐ 면책 고지 표준 문구 확정 (회사 검토)
- ☐ 의료자문위 구성 협의 (회사 측)
- ☐ 식약처 건강기능식품 원료 DB 수동 정리

Phase 1 (핵심 산출식 PoC)

- ☐

알고리즘 코드 주석에 출처 명시 (KDRIs 2020 등)

☐

LLM 시스템 프롬프트에 표현 가이드 포함

☐

금지 표현 자동 검출 함수 구현

☐

만성질환자 권고 문구 검수

Phase 2 (영양제 OCR MVP)

☐

별도 동의 UI 구현 (3가지 민감정보 항목)

☐

모든 권고 화면에 메인 디스클레이머

☐

영양제 화면에 부속 디스클레이머

☐

AES-256 컬럼 암호화 (만성질환·복약 정보)

☐

TLS 1.3 적용

☐

PHI 접근 감사 로그

Phase 3 (식단·AI 고도화)

☐

의료자문위 알고리즘·표현 검토 통과

☐

영양제 추천 문구 식약처 기능성 표시 기준 검수

☐

DTx 해당 여부 법률 전문가 사전 검토

☐

위급 신호 감지 룰 구현

☐

응급 자원 정보 페이지

Phase 4 (발표·시연)

☐

법무 검수 통과 (진단·처방 표현 0건)

☐

정보 출처 페이지 구현

☐

App Privacy 라벨 (Apple)

- ☐
- Data Safety 섹션 (Google Play)
- ☐
- 개인정보처리방침 페이지 게시

정식 출시 전 (Year 1 후반)

- ☐
- ISMS-P 갭 분석 → 컨설팅 착수
- ☐
- FHIR KR Core API 설계 (LDB 연동 시)
- ☐
- AES-256 컬럼 암호화 + TLS 1.3 강제 검증
- ☐
- PHI 접근 감사 로그 시스템 구축
- ☐
- 데이터 유출 대응 모의 훈련

운영 중 (Year 2+)

- ☐
- KDRIs 개정 시 즉시 록업 테이블 갱신
- ☐
- 보건복지부 비의료 건강관리서비스 가이드라인 갱신 시 즉시 재검토
- ☐
- 의료자문위 분기별 알고리즘 검토
- ☐
- 가명정보 가이드라인 갱신 모니터링

 변경 이력

버전	날짜	변경 사항	작성자
v1.0	2026-05-03	초안 작성. 5개 법규 + ISMS-P + DTx + 앱스토어 + 표현 + 비상대응 통합	TBD

 관련 문서

- 01. 프로젝트 개요
- 02. 배경 및 문제 정의
- 05. GitHub 협업 규칙 (보안 부분)
- 06. 기술 스택 (AES-256·TLS 1.3 부분)

- 07. 핵심 알고리즘 (표현 가이드 적용)
- 08. 구현 계획 (Phase별 적용)
- 09. 데이터·API 카탈로그 (라이선스·거버넌스)